

ComplianceCheck

Pay-as-you-go Compliance Assessments for Indian SMEs

DPDP Act Compliance Gap Assessment Report

Digital Personal Data Protection Act, 2023

DPDP Rules, 2025

Prepared For

Sample Enterprises Pvt Ltd

Maharashtra | Manufacturing

Employees: 51-100

Assessment Date: 25 July 2026

34%

Overall Compliance Score

Executive Summary

34%

Overall Compliance Score

Risk Level

Critical Risk

Penalty Exposure

Up to Rs. 250 Cr

Category-wise Compliance

Category	Score	Compliance
Consent Management	33%	3/9
Security Safeguards	33%	3/9
Data Principal Rights	33%	2/6
Breach Response	40%	2/5
Children's Data Protection	40%	2/5
Governance & Retention	25%	1/4

Key Findings

- * Total Compliance Score: 34%
- * Risk Level: Critical Risk
- * Areas Requiring Attention: 25 High Priority Items
- * Compliant Areas: 13 areas meet requirements

HIGH Priority Action Items

Address immediately to mitigate compliance risks.

HIGH

Consent Management

Easy Consent Withdrawal (Withdrawal Parity)

"DPDP Act 2023 - Section 6(4) | DPDP Rules 2025 - Rule 3(3)"

- Steps to Address:
- 1. Implement one-click consent withdrawal matching consent mechanism
 - 2. Create self-service consent management portal accessible from user account
 - 3. Do NOT require: login, multiple steps, email verification, or phone calls for withdrawal
 - 4. Process withdrawal within 24 hours and send confirmation
 - 5. Stop processing immediately upon withdrawal (except legal obligations)

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for making withdrawal difficult

Ref: DPDP Act 2023 - Section 6(4) | DPDP Rules 2025 - Rule 3(3)

HIGH

Consent Management

Multilingual Privacy Notices

"DPDP Act 2023 - Section 5(1) | DPDP Rules 2025 - Rule 3"

- Steps to Address:
- 1. Provide notices in Hindi and English at minimum
 - 2. Add regional languages based on user demographics (22 scheduled languages)
 - 3. Implement language detection and automatic locale selection
 - 4. Ensure translations are legally accurate, not just machine-translated
 - 5. Test notices with native speakers for clarity

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for non-compliant notices

Ref: DPDP Act 2023 - Section 5(1) | DPDP Rules 2025 - Rule 3

HIGH

Consent Management

Consent Record Keeping

"DPDP Act 2023 - Section 6 | DPDP Rules 2025 - Rule 3"

- Steps to Address:
- 1. Implement consent logging with: timestamp, IP address, user agent, consent version
 - 2. Store consent records for minimum 7 years (recommended)
 - 3. Enable audit trail retrieval by user ID or date range
 - 4. Include proof of what user was shown at time of consent
 - 5. Implement tamper-proof consent storage

Deadline: 13 May 2027

Penalty: Unable to demonstrate lawful processing - Up to Rs. 250 Cr

Ref: DPDP Act 2023 - Section 6 | DPDP Rules 2025 - Rule 3

HIGH

Consent Management

Re-consent for Policy Changes

"DPDP Act 2023 - Section 5, 6 | DPDP Rules 2025"

Steps to Address:

1. Implement notice version control with change tracking
2. Notify users of material changes via email and in-app notification
3. Re-obtain consent when adding new processing purposes
4. Maintain archive of all previous notice versions with dates
5. Give users 30-day notice period before changes take effect

Deadline: 13 May 2027

Penalty: Processing without valid consent - Up to Rs. 50 Cr

Ref: DPDP Act 2023 - Section 5, 6 | DPDP Rules 2025

HIGH

Consent Management

Third-Party Data Sharing Consent

"DPDP Act 2023 - Section 6(1), 8(2) | DPDP Rules 2025 - Rule 9"

Steps to Address:

1. Obtain separate, explicit consent before sharing data with any third party
2. Clearly identify each third party and their purpose in consent flow
3. Implement data processing agreements with all third parties
4. Provide users visibility into which third parties have their data
5. Enable users to revoke third-party sharing consent independently

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for unauthorized third-party sharing

Ref: DPDP Act 2023 - Section 6(1), 8(2) | DPDP Rules 2025 - Rule 9

HIGH

Consent Management

Consent Version History Tracking

"DPDP Act 2023 - Section 6 | Best Practice"

Steps to Address:

1. Implement version control for all consent forms and privacy notices
2. Track which consent version each user agreed to
3. Store historical versions with effective date ranges
4. Enable retrieval of consent state at any point in time
5. Create dashboard for consent version analytics

Deadline: 13 May 2027

Penalty: Inability to demonstrate compliance - Up to Rs. 50 Cr

Ref: DPDP Act 2023 - Section 6 | Best Practice

HIGH

Security Safeguards

Encryption in Transit

"DPDP Act 2023 - Section 8(4) | DPDP Rules 2025 - Rule 6"

Steps to Address:

1. Implement TLS 1.3 for all external data transfers (minimum TLS 1.2)
2. Enable HTTPS everywhere - no exceptions for any personal data
3. Disable weak ciphers and SSL/early TLS versions
4. Implement certificate pinning for mobile apps
5. Use encrypted connections for internal services handling personal data

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for inadequate transit security

HIGH

Security Safeguards

Tokenization and Data Masking

"DPDP Act 2023 - Section 8(4) | DPDP Rules 2025 - Rule 6"

Steps to Address:

1. Implement tokenization for Aadhaar, PAN, and payment card data
2. Mask sensitive data in non-production environments
3. Use format-preserving encryption where tokenization not feasible
4. Ensure display masking in UI (show only last 4 digits)
5. Implement data masking for analytics and reporting

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for exposing sensitive identifiers

Ref: DPDP Act 2023 - Section 8(4) | DPDP Rules 2025 - Rule 6

HIGH

Security Safeguards

Audit Logging and Retention

"DPDP Rules 2025 - Rule 6(2) | Rule 12"

Steps to Address:

1. Log all access to personal data with: user ID, timestamp, action, record accessed
2. Retain logs for minimum 1 year as per DPDP Rules
3. Implement log integrity protection (write-once storage, digital signatures)
4. Set up real-time alerting for suspicious access patterns
5. Enable log export for regulatory requests

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for inadequate security measures

Ref: DPDP Rules 2025 - Rule 6(2) | Rule 12

HIGH

Security Safeguards

Intrusion Detection Systems

"DPDP Act 2023 - Section 8(4) | IT Act 2000"

Steps to Address:

1. Deploy network-based intrusion detection/prevention systems (IDS/IPS)
2. Implement endpoint detection and response (EDR) on all systems
3. Configure 24/7 monitoring with SOC capabilities
4. Establish automated threat response playbooks
5. Integrate threat intelligence feeds for proactive defense

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for security failures leading to breach

Ref: DPDP Act 2023 - Section 8(4) | IT Act 2000

HIGH

Security Safeguards

Vulnerability Assessment

"DPDP Act 2023 - Section 8(4) | CERT-In Guidelines"

Steps to Address:

1. Implement continuous vulnerability scanning for all public-facing assets
2. Conduct quarterly penetration testing by certified third parties
3. Establish vulnerability remediation SLAs (critical: 72hrs, high: 7 days)
4. Subscribe to security advisories for all software components
5. Document and track all vulnerabilities to closure

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for security negligence

HIGH

Security Safeguards

Secure Software Development (SSDLC)

"DPDP Act 2023 - Section 8(4) | OWASP Best Practice"

Steps to Address:

1. Implement security requirements in all development projects
2. Conduct threat modeling during design phase
3. Enable static code analysis (SAST) in CI/CD pipeline
4. Perform security testing before production deployment
5. Train developers on secure coding practices annually

Deadline: 13 May 2027

Penalty: Up to Rs. 250 Cr for security-by-design failures

Ref: DPDP Act 2023 - Section 8(4) | OWASP Best Practice

HIGH

Data Principal Rights

Right to Correction

"DPDP Act 2023 - Section 12 | DPDP Rules 2025 - Rule 5"

Steps to Address:

1. Provide self-service profile editing for basic fields
2. Create correction request workflow for restricted fields
3. Maintain audit trail of all corrections with timestamps
4. Propagate corrections to all systems including backups
5. Notify third parties who received incorrect data

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for failing to correct inaccurate data

Ref: DPDP Act 2023 - Section 12 | DPDP Rules 2025 - Rule 5

HIGH

Data Principal Rights

Right to Erasure (Right to be Forgotten)

"DPDP Act 2023 - Section 12(2) | DPDP Rules 2025 - Rule 5"

Steps to Address:

1. Build erasure request processing workflow
2. Implement automated deletion across all systems and backups
3. Document legitimate exceptions: legal compliance, ongoing disputes, tax records
4. Provide erasure confirmation within 30 days
5. Notify third parties to erase shared data

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for failing to erase data

Ref: DPDP Act 2023 - Section 12(2) | DPDP Rules 2025 - Rule 5

HIGH

Data Principal Rights

Timely Response to Rights Requests

"DPDP Act 2023 - Section 11, 12 | DPDP Rules 2025 - Rule 5"

Steps to Address:

1. Define and publish response timelines for each request type
2. Implement request tracking with automated reminders
3. Create escalation process for requests approaching deadline
4. Acknowledge receipt of all requests within 48 hours
5. Provide regular status updates for complex requests

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for unreasonable delays

HIGH

Data Principal Rights

Nomination of Representative

"DPDP Act 2023 - Section 14 | DPDP Rules 2025 - Rule 5"

Steps to Address:

1. Create mechanism for users to nominate representative for rights exercise
2. Verify nominee identity before processing requests
3. Enable users to update or revoke nominations easily
4. Process requests from nominated representatives with same priority
5. Document nomination records with audit trail

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for not honoring nomination rights

Ref: DPDP Act 2023 - Section 14 | DPDP Rules 2025 - Rule 5

HIGH

Breach Response

72-Hour Breach Notification to DPB

"DPDP Act 2023 - Section 8(6) | DPDP Rules 2025 - Rule 7"

Steps to Address:

1. 72-hour clock starts from DETECTION, not confirmation
2. Pre-draft notification templates with placeholders
3. Establish 24/7 escalation path to authorized reporters
4. Create Data Protection Board contact database
5. Implement breach severity classification matrix

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr for late or missed notification

Ref: DPDP Act 2023 - Section 8(6) | DPDP Rules 2025 - Rule 7

HIGH

Breach Response

Affected Party Notification

"DPDP Act 2023 - Section 8(6) | DPDP Rules 2025 - Rule 7"

Steps to Address:

1. Create notification templates covering: breach nature, data involved, consequences
2. Include recommended protective actions for users
3. Establish communication channels: email, SMS, in-app, public notice
4. Provide helpline/FAQ for affected individuals
5. Document notification evidence (delivery receipts)

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr for failing to notify affected individuals

Ref: DPDP Act 2023 - Section 8(6) | DPDP Rules 2025 - Rule 7

HIGH

Breach Response

Post-Incident Review and Remediation

"DPDP Act 2023 - Section 8(4) | Best Practice"

Steps to Address:

1. Conduct post-incident review within 2 weeks of incident closure
2. Document lessons learned and improvement recommendations
3. Track remediation actions with assigned owners and deadlines
4. Update security controls and procedures based on findings
5. Report incident patterns to senior management quarterly

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr for repeat incidents from same cause

HIGH

Children's Data Protection

Verifiable Parental Consent

"DPDP Act 2023 - Section 9 | DPDP Rules 2025 - Rule 8"

Steps to Address:

1. Implement age-gate at registration asking date of birth
2. For users under 18, trigger parental consent flow
3. Verification methods: DigiLocker token, government ID upload, video verification
4. Obtain consent from identified parent/guardian only
5. Maintain consent records with verification evidence

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr for processing children data without parental consent

Ref: DPDP Act 2023 - Section 9 | DPDP Rules 2025 - Rule 8

HIGH

Children's Data Protection

No Behavioral Tracking of Children

"DPDP Act 2023 - Section 9(2) | DPDP Rules 2025 - Rule 8"

Steps to Address:

1. IMMEDIATELY disable all tracking for users flagged as under 18
2. Remove children from advertising audiences and lookalike models
3. Disable behavioral cookies and analytics for children sessions
4. No profiling, recommendation engines based on children behavior
5. Audit ad tech stack for any children data processing

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr - ABSOLUTE PROHIBITION

Ref: DPDP Act 2023 - Section 9(2) | DPDP Rules 2025 - Rule 8

HIGH

Children's Data Protection

Deletion of Children's Data

"DPDP Act 2023 - Section 9 | DPDP Rules 2025 - Rule 8"

Steps to Address:

1. Implement mechanism for parents to request deletion of child data
2. Automatically flag children accounts for data minimization
3. Delete children data when consent is withdrawn or child ages out
4. Propagate deletion to all systems including backups
5. Confirm deletion to parent/guardian within 30 days

Deadline: 13 May 2027

Penalty: Up to Rs. 200 Cr for retaining children data improperly

Ref: DPDP Act 2023 - Section 9 | DPDP Rules 2025 - Rule 8

HIGH

Governance & Retention

Data Protection Officer (DPO) Designation

"DPDP Act 2023 - Section 10 | DPDP Rules 2025 - Rule 11"

Steps to Address:

1. Appoint India-based Data Protection Officer (mandatory for SDFs)
2. Ensure DPO has adequate authority and resources
3. Publish DPO contact details in privacy notice and on website
4. DPO must report to highest management level
5. Provide DPO with independence to perform duties without interference

Deadline: 13 May 2027

Penalty: Up to Rs. 150 Cr for inadequate governance

HIGH

Governance & Retention

Data Retention Policy

"DPDP Act 2023 - Section 8(5) | DPDP Rules 2025 - Rule 4"

Steps to Address:

1. Define retention periods for each data category aligned with legal requirements
2. Consider: consent validity, contract duration, statutory obligations (7 years for financial)
3. Implement automated deletion triggers when retention period expires
4. Create exception process for legal holds and dispute resolution
5. Document retention justification for each category

Deadline: 13 May 2027

Penalty: Up to Rs. 50 Cr for retaining data beyond necessary period

Ref: DPDP Act 2023 - Section 8(5) | DPDP Rules 2025 - Rule 4

HIGH

Governance & Retention

Employee Data Protection Training

"DPDP Act 2023 - Section 8 | Best Practice"

Steps to Address:

1. Implement mandatory annual data protection training for all employees
2. Specialized training for employees handling personal data
3. Include DPDP Act requirements, breach response, data principal rights
4. Track training completion and maintain attendance records
5. Update training content when regulations change

Deadline: 13 May 2027

Penalty: Up to Rs. 150 Cr for employee-caused violations

Ref: DPDP Act 2023 - Section 8 | Best Practice

Compliant Areas (13)

These areas meet Digital Personal Data Protection Act, 2023 requirements based on your responses

Consent Management

- [Y] Granular and Purpose-Specific Consent
- [Y] Purpose Limitation Compliance
- [Y] Cookie and Tracking Consent

Security Safeguards

- [Y] Encryption at Rest
- [Y] Role-Based Access Controls
- [Y] Backup and Recovery Testing

Data Principal Rights

- [Y] Right to Access (Data Subject Access Request)
- [Y] Grievance Redressal Mechanism

Breach Response

- [Y] Incident Response Plan
- [Y] Security Incident Documentation

Children's Data Protection

- [Y] Age Verification Mechanisms
- [Y] Transparent Communication with Parents

Governance & Retention

- [Y] Records of Processing Activities (ROPA)

Next Steps & Resources

Recommended Timeline

Period	Action
Immediate	Address HIGH priority items
Short-term (30-60 days)	Complete MEDIUM priority items
Ongoing	Implement LOW priority improvements
Annual	Re-assessment and compliance review

Government Resources

MeitY Data Protection Framework

<https://www.meity.gov.in/data-protection-framework>

Data Protection Board of India

<https://www.dataprotection.gov.in>

DPDP Act Full Text

<https://www.meity.gov.in/writereaddata/files/Digital%20Personal%20Data%20Protection%20Act%202023.pdf>

CERT-In (Breach Reporting)

<https://www.cert-in.org.in>

Applicable Legislation

- * Digital Personal Data Protection Act, 2023
- * DPDP Rules, 2025
- * Information Technology Act, 2000
- * IT (Reasonable Security Practices) Rules, 2011
- * CERT-In Directions (April 2022)

Key Compliance Deadlines

- * DPDP Act Full Compliance: 13 May 2027
- * Consent Manager Registration: Before processing personal data
- * Data Breach Notification to Board: Within 72 hours of discovery
- * Data Breach Notification to Principal: Without undue delay
- * Response to Data Erasure Request: Without unreasonable delay
- * Grievance Redressal Response: As prescribed by Rules

WARNING

DPDP Act compliance deadline: 13 May 2027. All Data Fiduciaries must be fully compliant by this date. Penalties up to Rs. 250 Crore for non-compliance.

Schedule Your Next Assessment

We recommend re-assessing your compliance status every 6-12 months. Visit compliancecheck.co.in to schedule your next assessment.

Disclaimer: This report is generated based on your responses and should not be construed as legal advice. Please consult with a legal professional for specific compliance guidance.

Report Generated: 25 July 2026

Assessment ID: SAMPLE-DPDP

Generated by ComplianceCheck.co.in | This report does not constitute legal advice